REPORT PROGETTO FINE MODULO -M5-

Analisi del Rischio e Progettazione della Sicurezza per un' Applicazione Web E-Commerce.

Analisi delle minacce, azioni preventive, impatto sul business e risposta agli incidenti per una piattaforma e-commerce.

Classificazione	Architettura	Versione
High Level Design	DMZ / Firewall / WAF	1.0

Introduzione

Il presente report affronta la sicurezza di una piattaforma di e-commerce esposta su Internet avente l'obiettivo di progettare e documentare una strategia di sicurezza completa, seguendo un approccio **High Level Design (HLD)**: non si descrivono configurazioni di dettaglio, ma le scelte architetturali, i componenti introdotti e le motivazioni che le giustificano dal punto di vista della sicurezza informatica aziendale.

L'architettura baseline presenta una criticità strutturale rilevante: il server applicativo risiede in una **DMZ (Demilitarized Zone)** raggiungibile dalla rete interna aziendale tramite policy sul firewall.
Questa configurazione espone l'intera infrastruttura a un rischio di **movimento laterale**: una compromissione del server in DMZ potrebbe consentire all'attaccante di raggiungere i sistemi interni critici; partendo da questa vulnerabilità, il report sviluppa una risposta progressiva e strutturata.

Il documento si articola in cinque sezioni: la **prima** descrive l'architettura baseline e le sue vulnerabilità.
La **seconda** introduce le azioni preventive contro attacchi SQLi e XSS tramite WAF, sanitizzazione dell'input e formazione del personale, applicando il principio di ***defense-in-depth***.
La **terza** quantifica l'impatto economico di un attacco DDoS e propone strumenti di governance (BIA, BCP, IRP) per garantire la continuità operativa.
La **quarta** analizza la risposta a un'infezione malware, con la strategia di isolamento della rete interna e monitoraggio passivo tramite IDS.
La **quinta** propone un'infrastruttura rafforzata con piano di investimento dettagliato da **€25.000**, dimostrando come il ROI della sicurezza sia positivo già al primo incidente evitato.

00 — Architettura di Riferimento (Baseline)

Contesto: L'applicazione di e-commerce deve essere disponibile su Internet per consentire agli utenti di effettuare acquisti.
Il server applicativo risiede in una **DMZ (Demilitarized Zone)**, separata dalla rete interna aziendale tramite un firewall perimetrale.
Il problema strutturale dell'architettura baseline è che la **rete interna è raggiungibile dalla DMZ** secondo le policy del firewall: se il server in DMZ viene compromesso, un attaccante potrebbe muoversi lateralmente verso i sistemi interni.

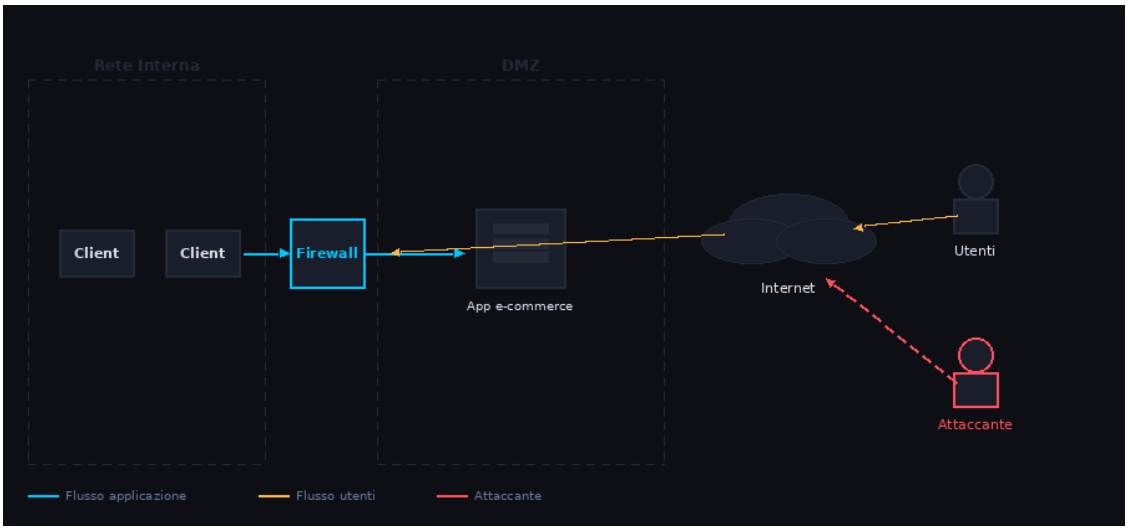

Fig. 00 — Architettura baseline: server e-commerce in DMZ, rete interna raggiungibile tramite firewall.

01 — Azioni Preventive: Difesa da SQLi e XSS

Gli attacchi **SQL Injection (SQLi)** e **Cross-Site Scripting (XSS)** sfruttano l'insufficiente validazione degli input dell'applicazione.
In un'architettura HLD, la difesa si struttura su **tre livelli indipendenti (defense-in-depth)**: perimetro, applicazione e processo.

Controlli implementati

Livello	Controllo	Minaccia mitigata	Priorità
Perimetro	**WAF – Web Application Firewall** Filtra il traffico HTTP/HTTPS in ingresso prima che raggiunga il server applicativo. Utilizza ruleset basati su OWASP CRS (Core Rule Set).	SQLi, XSS, LFI, RFI, Bot	**ALTA**
Applicazione	**Input Validation & Sanitization** Prepared Statements / Parameterized Queries per SQLi. Output encoding e Content Security Policy (CSP) per XSS.	SQLi, XSS Stored/Reflected	**ALTA**
Applicazione	**OWASP Top 10 Compliance** Sviluppo e revisione del codice seguendo le linee guida OWASP. Utilizzo di OWASP ZAP per vulnerability scanning pre-produzione.	Vulnerabilità Top 10	**MEDIA**
Processo	**Formazione del personale** Awareness su phishing, gestione credenziali, riconoscimento comportamenti anomali. Il fattore umano rimane il vettore più sfruttato.	Social engineering, credenziali deboli	**MEDIA**

> **PRINCIPIO HLD — Defense in Depth**
> Nessun singolo controllo è sufficiente. Il WAF blocca gli attacchi noti, la sanitizzazione protegge dai bypass, la policy OWASP riduce le vulnerabilità alla radice.
> I tre livelli operano in modo indipendente: il fallimento di uno non compromette gli altri.

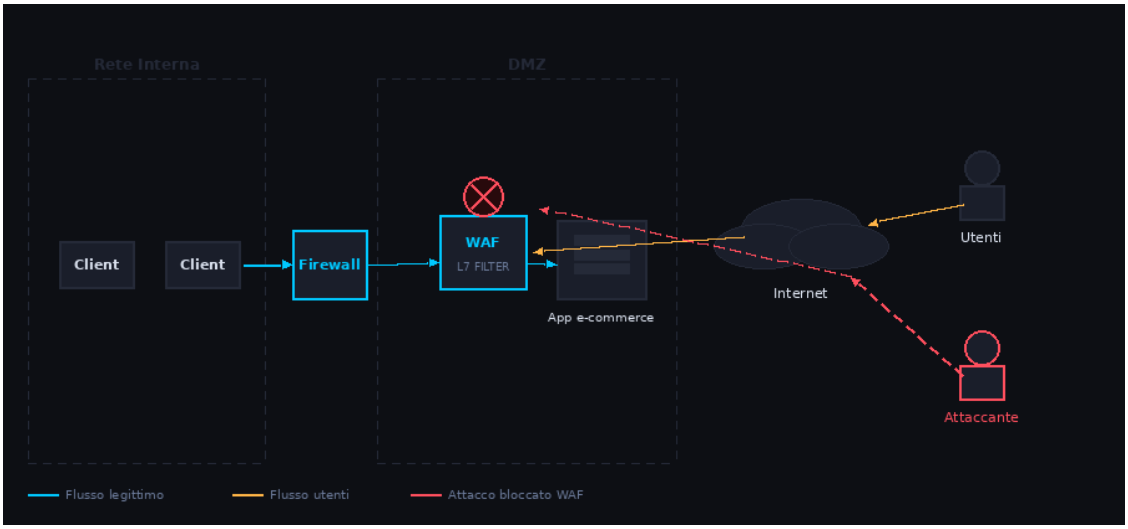

Fig. 01 — Il WAF intercetta le richieste malevole (SQLi, XSS) prima che raggiungano il server applicativo.

02 — Impatti sul Business: Attacco DDoS

Un attacco **DDoS (Distributed Denial of Service)** satura le risorse dell'applicazione rendendola irraggiungibile per gli utenti legittimi.
Il danno non è solo immediato: episodi ripetuti erodono la fiducia dei clienti e possono tradursi in perdita permanente di quota di mercato.

Calcolo dell'impatto economico

Durata downtime	Perdita per minuto	Perdita diretta totale	Danno indiretto
10 min Servizio non raggiungibile	**€ 1.500** Spesa media utenti	**€ 15.000** = 10 min × €1.500	**Alto** Reputazione, churn clienti

FORMULA

Impatto economico diretto = durata downtime (minuti) × fatturato per minuto
10 min × €1.500/min = **€15.000 di perdita diretta stimata**

Strumenti di governance per la continuità operativa

Framework	Scopo	Applicazione al caso DDoS
BIA *Business Impact Analysis*	Identificare le risorse critiche e quantificare l'impatto di un'interruzione.	Evidenzia €1.500/min → €15.000 in 10 min. Definisce RTO e RPO per il servizio e-commerce.
BCP *Business Continuity Plan*	Garantire la continuità operativa durante e dopo un incidente.	Failover su CDN/cloud ridondante. Replica geografica. Attivazione sito mirror in caso di saturazione.
IRP *Incident Response Plan*	Procedura operativa per risposta, contenimento e ripristino.	Escalation immediata al provider CDN anti-DDoS. Comunicazione agli utenti. Post-mortem e aggiornamento policy.

AZIONI PREVENTIVE ANTI-DDOS

CDN con protezione DDoS integrata (es. Cloudflare) assorbe volumi massivi di traffico distribuendo il carico su data center globali.
Mitiga attacchi L3/L4 (volumetrici) e L7 (HTTP Flood).
Rate limiting e IP reputation filtering sul WAF riducono ulteriormente la superficie di attacco.

03 — Response: Contenimento Malware

Quando l'applicazione web viene infettata da un malware, la strategia di risposta ha due obiettivi distinti: **contenimento della propagazione** (priorità massima) e **analisi forense** (obiettivo secondario, non interferire con l'attaccante).

La scelta di non rimuovere l'accesso dell'attaccante è intenzionale: permette di monitorare il comportamento del malware in un ambiente controllato, raccogliere **IOC (Indicators of Compromise)** e migliorare le difese future.
Questa fase di osservazione passiva ha tuttavia una durata limitata: il criterio di uscita è definito nel piano IRP e prevede la bonifica non appena siano stati raccolti sufficienti IOC oppure nel momento in cui il malware mostri tentativi di propagazione attiva nonostante l'isolamento.
In quel caso si passa immediatamente alla fase di eradicazione e ripristino.

> **MISURA DI CONTENIMENTO PRINCIPALE**
> Isolamento della rete interna: il firewall recide il collegamento tra DMZ e rete interna. I client interni non possono comunicare con l'esterno né con la DMZ compromessa. Il malware non può muoversi lateralmente verso i sistemi critici.

IDS vs IPS — Motivazione della scelta

> **PERCHÉ IDS E NON IPS**
> Si sceglie un IDS (Intrusion Detection System) e non un IPS per evitare falsi positivi che potrebbero interrompere traffico legittimo in una fase delicata.
> L'IDS opera in modalità passiva: osserva, registra e notifica senza alterare il traffico; permette di rilevare movimenti laterali, tracciare tentativi di connessione e preparare una risposta mirata basata su evidenze reali.

Componenti della risposta

- **Isolamento rete interna:** Disconnessione firewall tra DMZ e rete interna: il collegamento viene reciso per impedire la propagazione laterale del malware.
- **IDS passivo:** L'IDS (es. Suricata) viene posizionato tra i segmenti della rete interna per monitorare passivamente il traffico senza alterarlo.
- **SIEM centralizzato:** Tutti gli eventi e i log del traffico vengono inviati al SIEM per l'analisi centralizzata, utile per il post-mortem e per aggiornare il piano IRP.
- **Accesso attaccante mantenuto:** L'attaccante mantiene l'accesso alla DMZ: questo permette di studiarne le tecniche, raccogliere IOC e pianificare una risposta mirata.

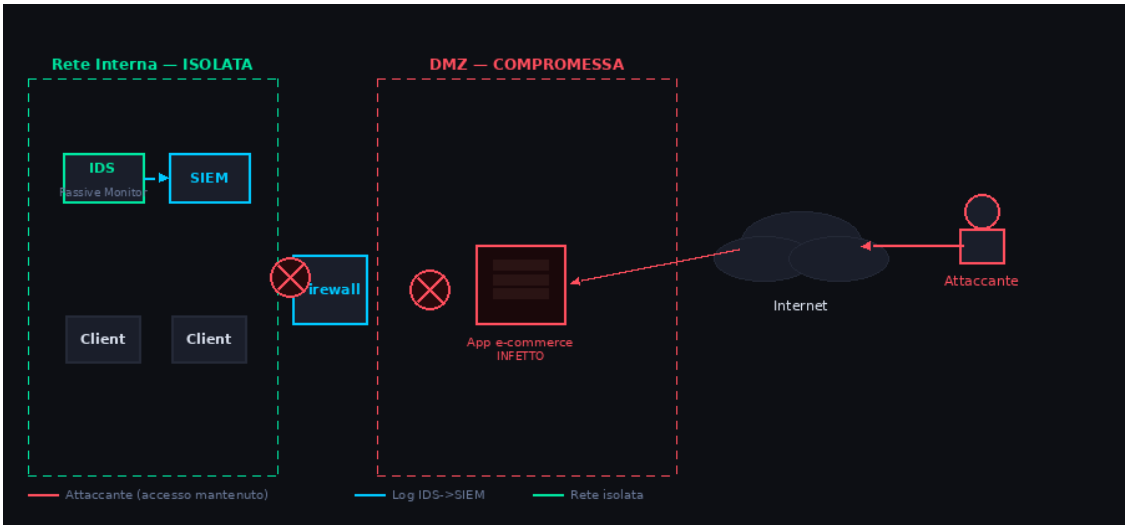

Fig. 03 — Contenimento malware: rete interna isolata, IDS passivo, SIEM attivo. Attaccante mantiene accesso DMZ.

04 — Soluzione Completa: Preventiva + Response

L'architettura completa integra in un unico design tutti i controlli preventivi (WAF, sanitizzazione input) e le misure di risposta (isolamento rete interna, IDS, SIEM). Questo rappresenta il **target architecture** dell'infrastruttura.

Componenti dell'architettura completa

- **Firewall:** Firewall perimetrale tra Internet/DMZ e rete interna con regole di segmentazione strict.
- **WAF (L7):** WAF posizionato davanti al server e-commerce, con ruleset OWASP CRS per bloccare SQLi, XSS e altri attacchi L7.
- **IDS:** Suricata IDS in modalità passiva sulla rete interna per rilevare movimenti laterali.
- **SIEM:** SIEM per la raccolta centralizzata dei log provenienti da firewall, WAF e IDS.
- **Isolamento:** Politica di isolamento attivabile in caso di incidente: recisione del collegamento DMZ → rete interna.

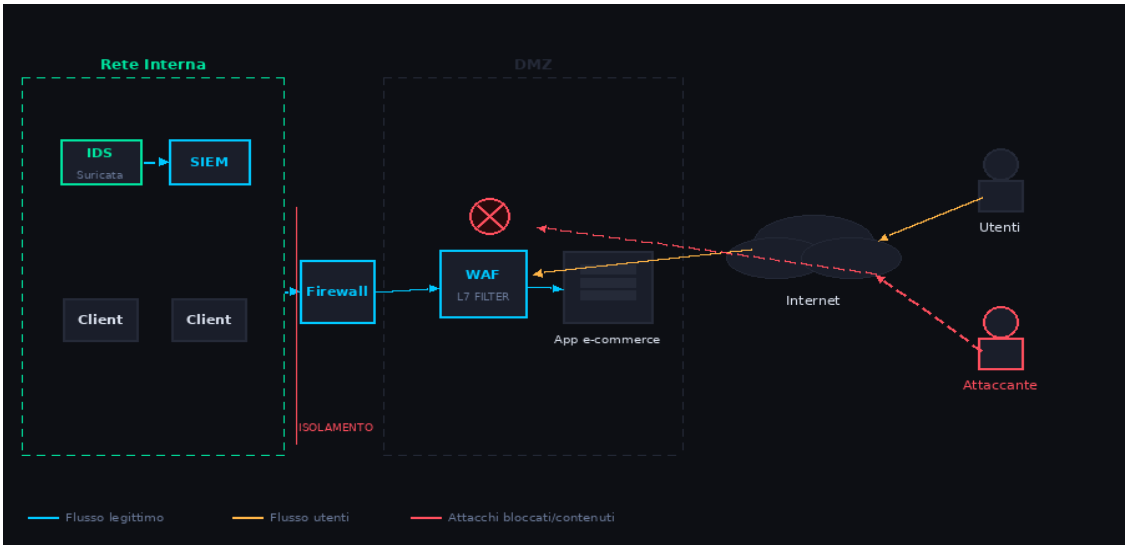

Fig. 04 — Architettura completa: WAF + Firewall + IDS + SIEM + isolamento rete interna in caso di incidente.

05 — Infrastruttura Rafforzata: Approccio Aggressivo

L'approccio "più aggressivo" sostituisce soluzioni reattive con una **postura proattiva e ridondante**, integrando protezione DDoS cloud-based, firewall di nuova generazione (NGFW), backup automatizzati, disaster recovery e penetration test periodici.

Budget disponibile: **€25.000 per 50 dipendenti.**

Piano di investimento

#	Soluzione	Componenti	Costo	Priorità
1	**Protezione DDoS + WAF Cloud** Anti-DDoS + WAF	Cloudflare Business : protezione L3/L4/L7, WAF incluso, anycast network globale.	€ 2.400/anno	**CRITICA**
2	**NGFW** Next Generation Firewall	Fortinet FortiGate 60F : IPS, anti-malware AI, filtraggio DNS/URL, controllo app, antispam.	€ 2.290 (3 anni)	**CRITICA**
3	**IDS Interno** Suricata + pfSense	Suricata (open source) su mini-PC dedicato con pfSense. Software gratuito.	€ 500 (hardware)	**ALTA**
4	**Backup Automatizzati** Veeam + Wasabi	Veeam Backup + Wasabi Cloud Storage (10 TB stimati). Protezione da ransomware e guasti.	€ 5.040/anno	**CRITICA**
5	**Disaster Recovery** VPS DR su OVHCloud	Replica applicativa su VPS secondaria attivabile manualmente in caso di disastro.	€ 2.400 (2 anni)	**ALTA**
6	**Formazione Personale** KnowBe4 Diamond	50 dipendenti :anti-phishing, security awareness, riduzione rischio umano.	€ 1.650/anno	**ALTA**
7	**Penetration Test** Web App Pen Test	Pen test completo sull'applicazione e-commerce + identificazione vulnerabilità pre-produzione.	€ 5.000 (una tantum)	**MEDIA**

INVESTIMENTO TOTALE STIMATO	€ 19.280
Fondi residui per emergenze / interventi straordinari	**€ 5.720**

VALORE DELL'INVESTIMENTO

Un singolo attacco DDoS di 10 minuti costa €15.000 di perdita diretta.
L'intero piano annuale costa €19.280 e copre DDoS, malware, backup, DR e formazione.
Il ROI della sicurezza è immediatamente positivo anche con un solo incidente evitato.

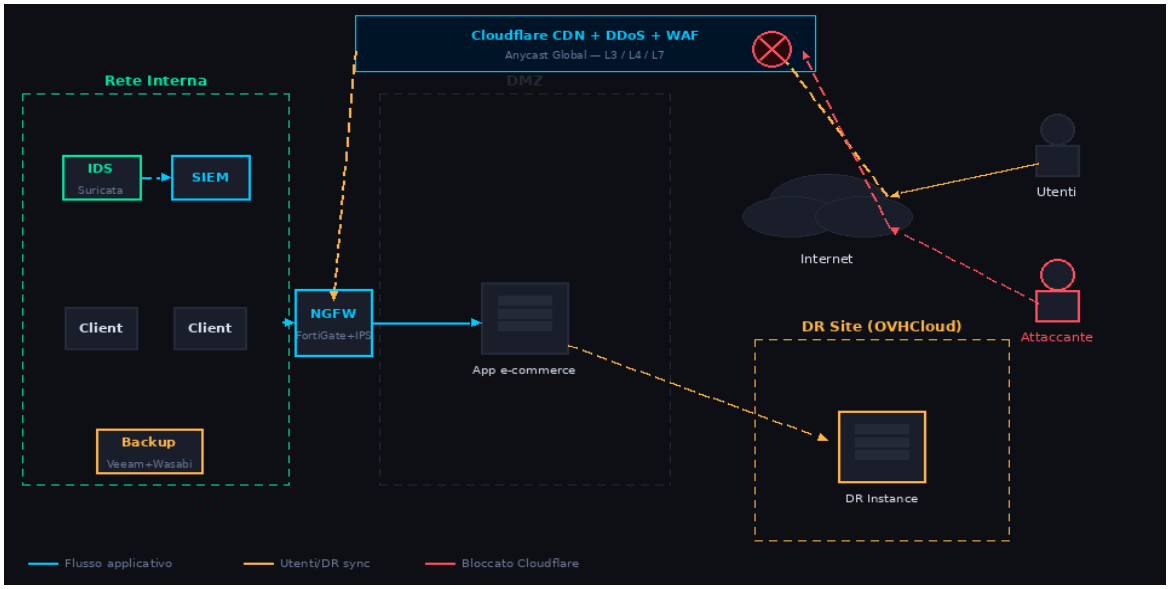

Fig. 05 — Architettura aggressiva: Cloudflare CDN+WAF, NGFW FortiGate, IDS Suricata, SIEM, Backup Veeam+Wasabi, DR su OVHCloud.

Conclusioni

Il presente report ha analizzato l'architettura di sicurezza di un'applicazione web di e-commerce partendo dalla configurazione baseline e progredendo verso una soluzione completa e rafforzata.
L'analisi ha evidenziato come la sicurezza informatica non possa essere affrontata con un approccio singolo e reattivo, ma richieda una **strategia multilivello, proattiva e strutturata**.

Sul fronte della **prevenzione**, l'introduzione del WAF con ruleset OWASP, combinata con la sanitizzazione dell'input lato applicativo e la formazione continua del personale, costituisce una difesa solida contro le minacce più diffuse come SQLi e XSS.
Il principio di **defense-in-depth** garantisce che il fallimento di un singolo controllo non comprometta l'intera infrastruttura.

Sul fronte dell'**impatto economico**, il calcolo ha dimostrato che anche un'interruzione breve (10 minuti di downtime DDoS)genera una perdita diretta di **€15.000**.
Questo dato giustifica pienamente l'investimento in soluzioni di protezione come CDN anti-DDoS e piani strutturati di BIA, BCP e IRP.
La governance della sicurezza è parte integrante della continuità aziendale, non un costo opzionale.

Sul fronte della **risposta agli incidenti**, la strategia di contenimento del malware tramite isolamento della rete interna e monitoraggio passivo con IDS dimostra come sia possibile bilanciare due obiettivi apparentemente contrapposti: proteggere i sistemi critici senza perdere la capacità di analisi forense sull'attaccante.
L'integrazione con il SIEM centralizzato trasforma ogni incidente in un'opportunità di miglioramento.

L'**architettura rafforzata** proposta nel piano di investimento da €25.000 rappresenta la risposta più matura e completa: con un budget inferiore al costo di due soli attacchi DDoS, l'azienda acquisisce protezione perimetrale avanzata (NGFW + Cloudflare), visibilità interna (IDS + SIEM), continuità operativa (backup + DR) e capacità di verifica proattiva (penetration test). **Il ROI della sicurezza è positivo già al primo incidente evitato.**

CONSIDERAZIONE FINALE

La sicurezza informatica non è uno stato da raggiungere, ma un processo continuo.
Le minacce evolvono, le vulnerabilità emergono e le infrastrutture cambiano.
Un'architettura ben progettata, combinata con formazione costante, monitoraggio attivo e test periodici, rappresenta la differenza tra un'azienda che subisce gli attacchi e una che li anticipa.